

6/XX 背景~研究目的

Windowsエンドポイントログを用いた正常 行動の行動復元列による偽陽性判断の検討

北海道大学 大学院情報科学研究院
情報理工学部門 複合情報工学分野 調和系工学研究室
修士課程2年 小松崎 大世

- Windowsエンドポイントセキュリティの重要性の増加
 - エンドポイント全体の一元管理が難しい
 - Windowsは市場の70%を占有
- 攻撃手法の変化によりインシデント分析の負担増加
 - 生成AIの発達により攻撃の多様化、未知攻撃の増加により異常検知では正確な検知が難しい
 - 見逃しを防ぐためにインシデント分析に回る構造

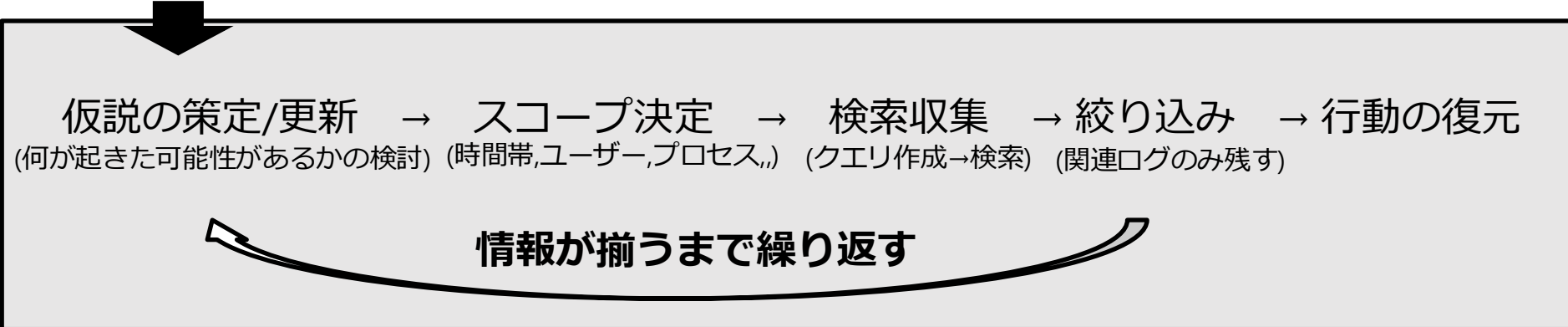
図：サイバー攻撃のインシデント対応ワークフロー

異常検知 → トリアージ → **インシデント分析** → 報告,レポート化

- インシデント分析とは
 - セキュリティ異常検知システムが出力した異常ログから調査を開始する
 - 異常ログを元に何が起きたのかを関連ログの収集により徐々に明らかにしていく作業
- インシデント分析の属人化
 - 高度な推論を繰り返すため、分析作業が属人化しやすい



セキュリティ
アラート

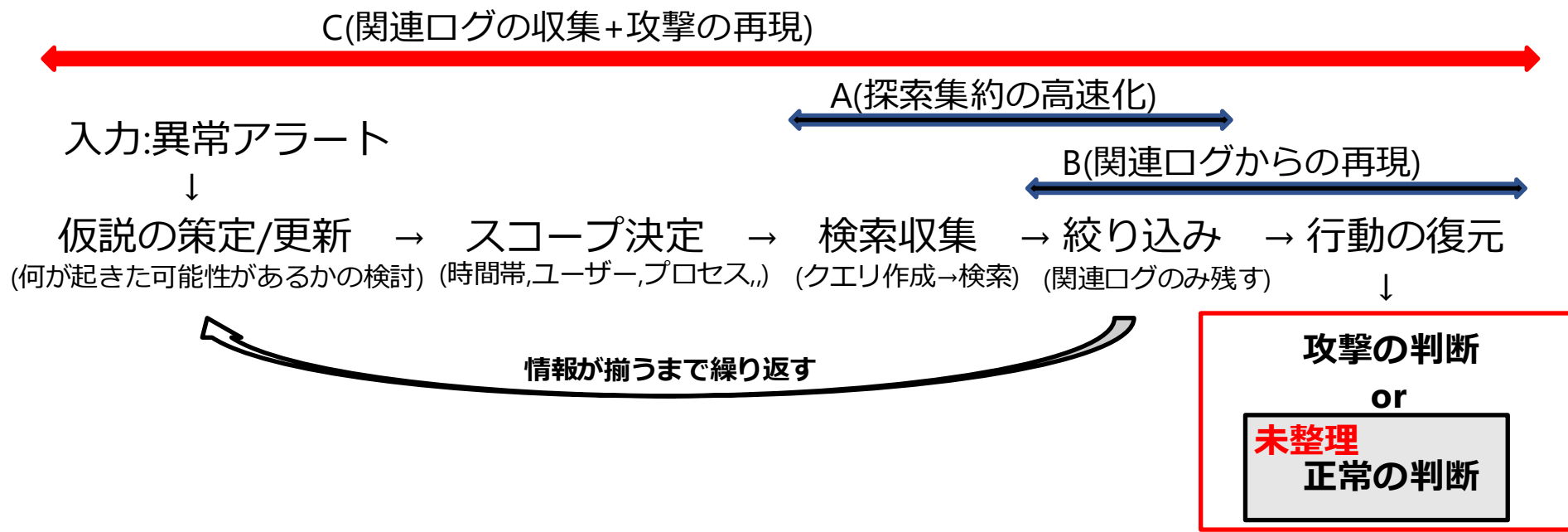


攻撃/正常の判断

- 機械/深層学習, LLMにより「A.探索集約の高速化」「B.関連ログから攻撃の再現」が可能に
 - ATLAS: A Sequence-based Learning Approach for Attack Investigation (USENIX Security 2021)
 - AIRTAG: Towards Automated Attack Investigation by Unsupervised Learning with Log Texts (USENIX Security 2023)
- マルチエージェントシステムにより「C.関連ログの収集+攻撃の再現」も実現されつつある
 - CLOUSEAU: A Hierarchical Multi-Agent Approach for Autonomous Attack Investigation (ACSAC 2025)

→攻撃を前提としたインシデント分析は実現されつつあるが、実務では偽陽性の解析が大半。
正常のログも含めた「関連ログの収集」「行動の復元」「正常の判断」は未整理

図：インシデント分析自動化研究の整理



6/10 網屋MTG

Windowsエンドポイントログを用いた正常
行動の行動復元列による偽陽性判断の検討

北海道大学 大学院情報科学研究院
情報理工学部門 複合情報工学分野 調和系工学研究室
修士課程2年 小松崎 大世

- 研究目的
 - 正常行動を対象としたインシデント分析支援手法の開発
- 手法
 - Multi-agentシステムを用いて正常の行動列を復元
 - 高度な推論を繰り返すインシデント分析はMulti-agentシステム以外では実現出来ない

問題設定：入力

7

- エンドポイントセキュリティシステムのアラートが入力
 - このアラートはインシデント分析が開始されるきっかけ
 - 時間、プロセス情報、アタクト内容が含まれる

例：Discord インストール時のアラート

time=2022-07-16 15:07:46

source_stream=cbc-edr-alerts

process=reg.exe

pid=5424

ppid=1204

parent=discord.exe

alert_id=CFnKBKLTv6hUkBGFobRdg-565631

alert_name=Discovery - Query Registry

reason=None

command_line=C:¥Windows¥System32¥reg.exe

query

HKCU¥Software¥Microsoft¥Windows¥CurrentVersion

¥Run /v Discord

時間

プロセス情報

検知情報

問題設定：データベース

- インシデント分析で復元する行動列の定義
 - ユーザー時間ごとに、「主体」「行動」「対象」が書かれた行動ステップを時系列で並べた行動列を出力

行動列の出力例：Discordをインストールした際の行動列 入力:reg.exe+時間

"timeline_ja": [

"1. [2022-07-16 15:07:46 付近 / ユーザー: WIN-32-H1¥¥aalsahee]

Discord.exe は初回起動または更新処理を示す ¥"--squirrel-firstrun¥" の文脈で動作し、その流れの中で **reg.exe** を子プロセスとして呼び出した。",

"2. [2022-07-16 15:07:46 付近 / ユーザー: WIN-32-H1¥¥aalsahee]

Discord.exe から起動された **reg.exe** は、C:¥¥Windows¥¥System32¥¥reg.exe query HKCU¥¥Software¥¥Microsoft¥¥Windows¥¥CurrentVersion¥¥Run /v Discord を実行し、**現在ユーザーの Run key** にある **Discord** 値を照会した。",

"3. [2022-07-16 15:07:46 付近 / ユーザー: WIN-32-H1¥¥aalsahee]

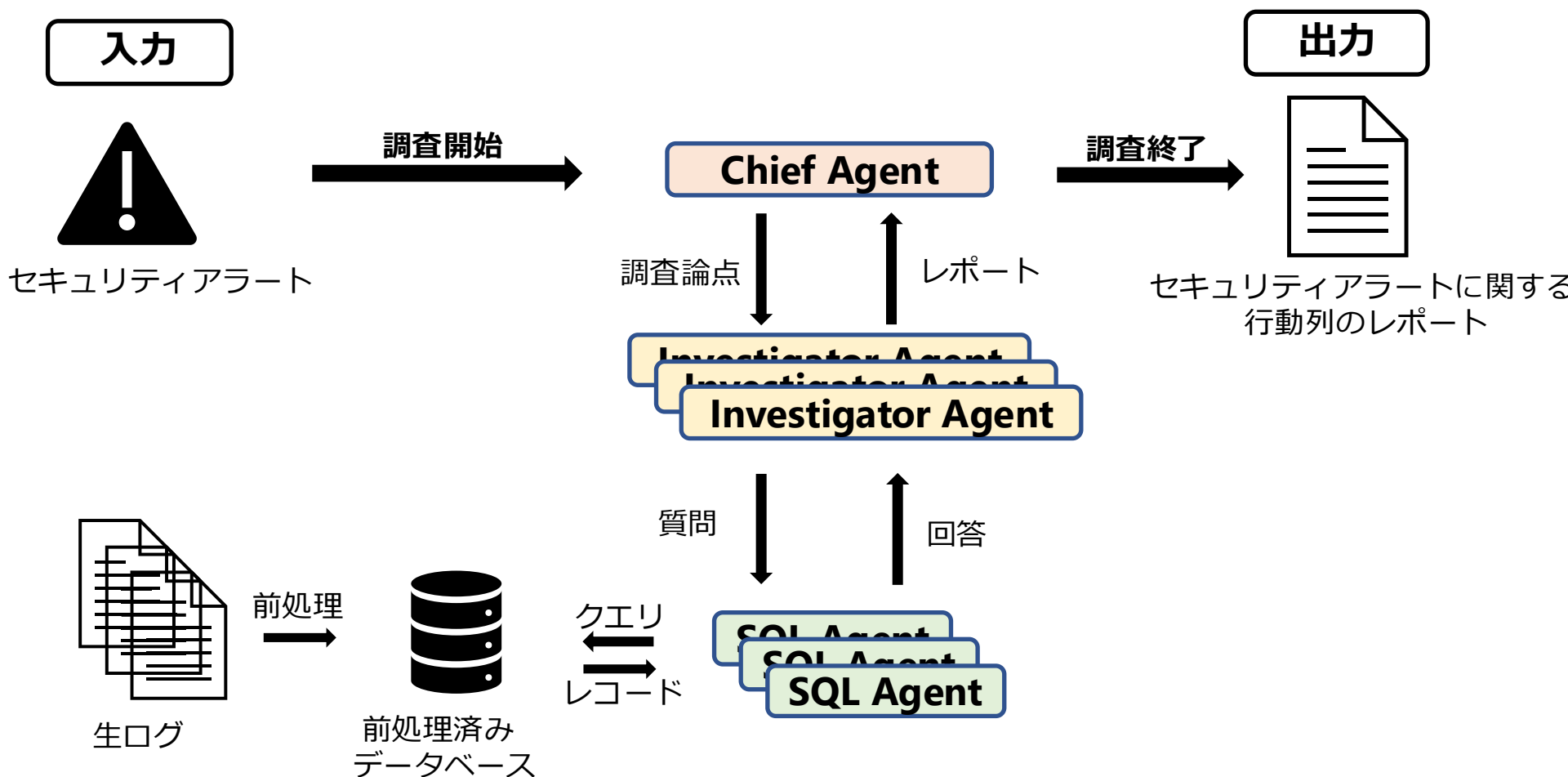
同じ Discord 関連のエピソード内で、**Run key の Discord 値は** C:¥¥Users¥¥aalsahee¥¥AppData¥¥Local¥¥Discord¥¥Update.exe --processStart Discord.exe に**関連する自動起動設定として追加または更新された可能性がある。**",

- 行動列を構成する行動ステップの定義
 - 行動ステップは「主体」「行動」「対象」「証跡」の4つの要素で構成される

行動ステップの出力例：reg.exeの親プロセスDiscord.exe

```
{ "order": 1,  
  "type": "実行文脈",  
  "step_summary_ja": "Discord.exe が動作している。",  
  (主体)  
  "subject": { "process_name": "Discord.exe", "role": "親プロセス" },  
  (行動)  
  "relation": "後続の reg.exe 実行の親プロセスとして観測された",  
  (対象)  
  "object": { "kind": "process", "value": "reg.exe" },  
  
  (証跡)  
  "evidence":  
  { "source_stream": "cbc-edr-alerts",  
    "timestamp": "2022-07-16 15:07:46",  
    "field": "parent_cmdline",  
    "value": "Discord.exe --squirrel-firststrun" } }
```

- セキュリティアラートを起点に、Chief・Investigator・SQL Agentが協調して関連ログを探索し、正常/攻撃の行動列として復元する



- Chief Agent : 全体の統括
 - 受け取ったセキュリティアラートから調査論点を作り下位のAgentに渡す
 - 調査の結果を受け取り新しい調査論点を作成する
 - 調査結果が全て出たタイミングで最終レポートを作成する

役割

あなたは CLOUSEAU の階層型調査パイプラインにおける Chief エージェントである。

目的

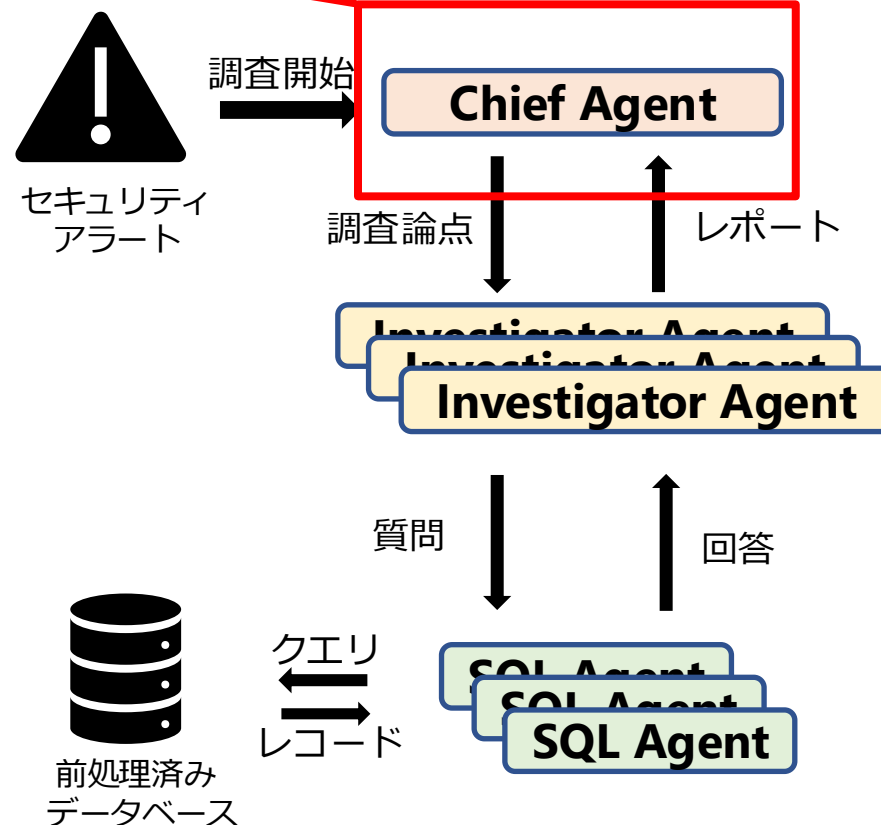
プロセス時刻起点から Windows エンドポイントの コード行動列を復元する。そのために、最初に「何を確認すべきか」という 調査論点を設計する。

調査論点 / 調査リード作成ルール

- alert title、command line、parent process、target object、application intent、behavior category を仮定しない。
- CBC alert 内容は起点情報の一部ではない。調査担当が database 内で発見した場合にだけ使う。
- 各調査論点には、調査対象、調査理由、確認したい証拠を含める。
- 近傍 row の接続関係は、先に決め打ちせず、観測証拠で検証する。

環境

{environment} ...
SOC からの起点情報
{initial_message}



- Investigator Agent : 調査担当者
 - 上位のAgentから受け取った調査論点を元に調査項目を作成
 - 調査項目を下位のAgentに渡すのみでデータベースのやり取りはしない
 - 調査が完了すると調査論点、調査結果と共に上位のAgentに返す

役割

あなたは CLOUSEAU 内の調査担当エージェントである。

目的

Chief の調査リードを、QAAgent に渡す 具体的で検証可能な調査質問へ変換する。

調査手順

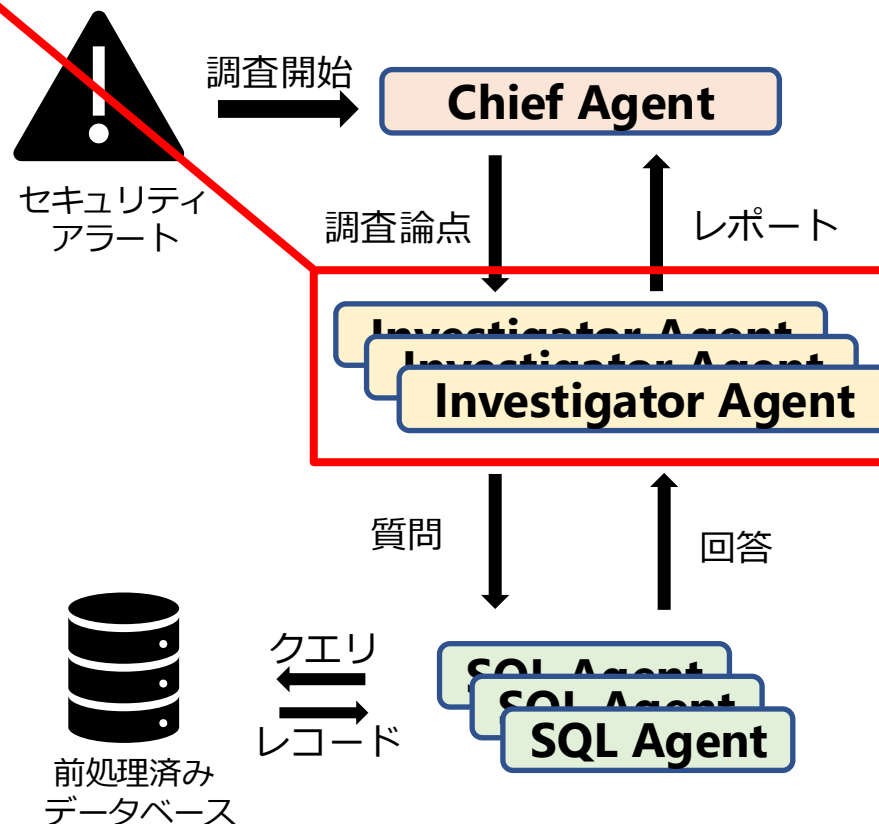
- 1.SOC の起点情報である host、process、timestamp から始める。
- 2.QAAgent への質問は自然言語だけにする。SQL、SELECT、WHERE、table/column recipe を書かない。
- ...
- 8.必要な証拠が揃うまで、直前の観測値に基づいて 追加質問を続ける。

有用な証拠

プロセス関係: pid、ppid、parent_process_name、parent_process_path、parent_command_line...

Chief の調査リード

{initial_message} ...



- SQL Agent : データベースの仲介役
 - 上位のAgentから受け取った調査項目を元にSQLクエリを作成
 - 調査項目とデータベースの検索結果を合わせて上位のAgentに返す

役割

あなたは QAAgent / SQL 専門エージェントである。

目的

ログ上の事実が必要な場合、run_sql_query で SQLite を検索して 調査担当の質問に答える。

重要な column

•audit_logs: time、pid、ppid、pname、process_name、access、object、event_record_id、event_id

...

プロセス時刻起点の SQL 探索ガイド

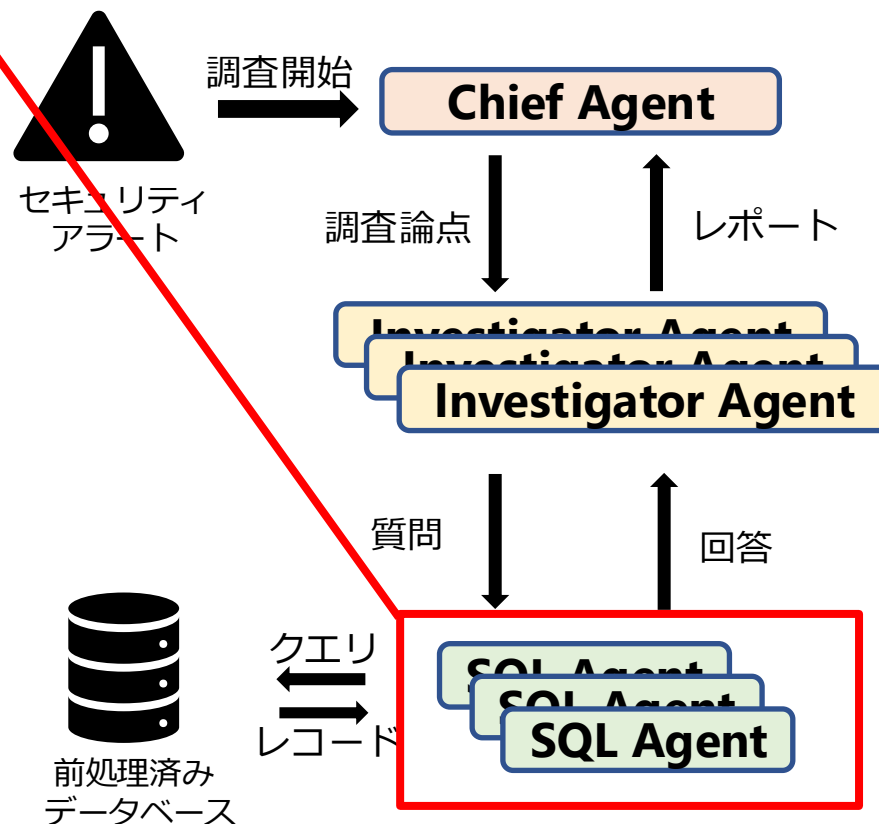
- 与えられた process と timestamp から始める。
- audit_logs.time の形式は 'YYYY-MM-DD HH:MM:SS' を使う。
- CBC alert field を入力から仮定しない。
- ...
- 10.値を作らない。unknown は null にする。

スキーマ

{schema} ...

質問

{question} ...



提案手法 Agent間のやり取り詳細

15

- Chief Agentが出した1つの論点での例
 - 1.reg.exeに関するセキュリティアラートが入力
 - 2. Chief Agentがreg.exe以外でレジストリにアクセスした記録が無いか調査論点として出す
 - 3. Investigator Agentが時間帯で区切り調査項目を作成する
 - 4. SQL Agentはデータベースから情報を検索する

Chief Agent 調査論点の提起

- ① 15:07~15:10の間にreg.exe以外でレジストリのRunキーにアクセスしたプロセスを調査する

Investigator Agent

- ② 質問1 15:07~15:10の間にreg.exe以外のプロセスがWindowsのRunキーに対して行ったレジストリ操作のログを教えてください

- ② 質問2 15:05~15:12の間にreg.exe以外のプロセスがWindowsのRunキーに対して行ったレジストリ操作のログを教えてください

- ④ 質問3 15:07~15:10でreg.exe以外のプロセスが自動起動設定に関するレジストリキーに対して行ったレジストリ操作を調査せよ

SQL Agent

- ③ SELECT time,access,process,.... No result

- ③ SELECT time,access,process,.... No result

- ⑤ SELECT time,access,process,.... No result

Chief Agent 調査結果の受け取り

- ⑥ 該当範囲ではレジストリのRunキーにアクセスしたプロセスがなかった

- 目的
 - CBC alertに頼らず、ログだけで正常の行動列を復元出来るかを検証する
 - 復元が可能であれば、正常調査中にCBC alertに記載のない行動列も発見出来る
- 実験設計
 - CBC alertの有無を3段階で変えることで、モデルの純粋なログ探索、復元能力を図る

ステージ	入力にCBC alertを含む	DBにCBC alertを含む	測りたいこと
Stage 1	あり	あり	CBC alertを手がかりに行動列を復元できるか
Stage 2	なし	あり	DBから自力でCBC alertに到達できるか
Stage 3	なし	なし	低レベルログのみから行動列を復元できるか

- 使用するデータセット
 - ATLAS v2
 - Windows エンドポイントログのオープンソースデータ
 - ログの種類が豊富で実務に近い
 - 正常期間に人が8時間×4日間作業しており実環境の再現がなされている

ATLAS V2 に含まれるログの種類

ログ種別	内容
Windows Security	Windows OSの監査ログ。ファイル/オブジェクトアクセス、認証、プロセス作成/終了、通信許可などを含む。
Sysmon	端末上の詳細なシステム活動ログ。プロセス作成/終了、親プロセス、コマンドライン、ProcessGuidなどを含む。
DNS	名前解決のログ。通信先ドメインの確認に使える。
Firefox	ブラウザ操作やWebアクセスの文脈を確認できる。
CBC アラート	Carbon Black EDRが観測した端末イベントのアラート

- 使用するユースケース
 - 選定条件
 - 1.実務でも調査対象になる攻撃/正常でも使用する正常コマンドや一般ツール関連のプロセス
 - 2.ATLAS v2内のCBCアラートで実際に偽陽性になっている
 - 選定結果
 - 1.MITRE ATT&CK、LOLBAを参考に96プロセスから5プロセス抽出
 - 2.5プロセスの中から、CBCアラートで偽陽性になっている時間を抽出
→合計27個の起点ログを抽出

27ユースケースの行動内訳

行動背景カテゴリ	件数	何をしている行動か	具体例
Pythonで簡易Webサーバを立てる行動	13	python.exe で簡易HTTPサーバを起動している	python -m SimpleHTTPServer
通信ログを取るためのバッチ実行	8	cmd.exe 経由でDNS/通信ログ収集用のバッチを動かしている	start_dns_logs.bat、tshark.exe
エディタからPythonスクリプトを実行する行動	3	Sublime Text から cmd.exe や python.exe が起動されている	hello.py、helloworld.py
コマンド経由で補助ツールを実行する行動	2	cmd.exe /c で別のツールやバッチを呼び出している	nvidia-smi.exe、run_http_server.bat
アプリが自動起動設定を登録する行動	1	Discord が reg.exe を使って Run key を追加・確認している	HKCU¥...¥Run¥Discord

- 目的
 - 段階的にセキュリティアラートの検知情報を抜くことで提案手法の行動復元能力を測る
- 場面
 - ベースラインではアラート情報を入力とするが段階的に検知情報にアクセス出来なくすることでログの探索、統合能力を測る

ステージ	見たいこと	入力	使用できるデータベース
Stage 1：アラート起点	アラート情報を手がかりに行動列を復元できるか	host, process, timestamp CBC alert 情報	CBC alert summary rows、CBC EDR/NGAV event Windows Security Sysmon DNS Browser history
Stage 2：入力からアラート除外	最小入力から DB 内のアラートや telemetry に到達できるか	host, process, timestamp (検知情報なし)	CBC alert summary rows、CBC EDR/NGAV event Windows Security Sysmon DNS Browser history
Stage 3：データベースからアラート除外	低レベル telemetry のみから対象行動を探索・統合できるか	host, process, timestamp (検知情報なし)	CBC EDR/NGAV event Windows Security Sysmon DNS Browser history (CBC alert summary row: 検知情報のデータベース は除外)

- 評価
 - 行動列、行動ステップの2軸で行動の復元能力を測る
 - 行動ステップの評価
 - 主体、対象、行動、コマンドライン、証跡の5要素をそれぞれ評価
 - 再現率と適合率で測る
 - 行動列の評価
 - 順序関係を2つセットで照らし合わせ評価する
 - Ex $A \rightarrow B \rightarrow C$ の時
 - $A \rightarrow B$ と $B \rightarrow C$ が一致するかを評価

評価レベル	指標	正解データで定義するもの
行動ステップ	再現率	正解行動ステップの必須要素: 主体, 行動, 対象, コマンドライン, 証跡
行動ステップ	適合率	正解行動ステップの必須要素: 主体, 行動, 対象, コマンドライン, 証跡
行動列	順序一致率	正解行動ステップ間の前後関係

- プレ実験としてDiscordのインストール時のプロセス行動を評価する
 - 3段階の実験場面とGPT4.1-miniとGPT5.4-miniで評価する

Discordの正解データ

Step	主体	行動	対象	コマンドライン	証跡
D1	Discord.exe	reg.exe を子プロセスとして起動	reg.exe	なし	Discord.exe と reg.exe の親子関係
D2	reg.exe	Run key の Discord 値を照会	HKCU¥Software¥Microsoft¥Windows¥CurrentVersion¥Run¥Discord	reg.exe query HKCU¥Software¥Microsoft¥Windows¥CurrentVersion¥Run /v Discord	CBC EDR / alert / process telemetry 上の query 証跡
D3	reg.exe	Run key の Discord 値を追加 / 更新	HKCU¥Software¥Microsoft¥Windows¥CurrentVersion¥Run¥Discord = ...Update.exe --processStart Discord.exe	reg.exe add HKCU¥Software¥Microsoft¥Windows¥CurrentVersion¥Run /v Discord /d "...Discord¥Update.exe --processStart Discord.exe" /f	ACTION_WRITE_VALUE, regmod_name, CBC EDR/NGAV telemetry

- 結果
 - 情報が集約されたアラート情報が行動復元に大きく寄与していたことが分かった
 - 先行研究で攻撃の行動復元が出来ていたgpt 4.1-miniでも正常の行動復元は出来なかったがgpt5.4-miniでは出来た
→入力で書かれていないことをログから自力で復元出来た

プレ実験結果：各条件で1回ずつ試行

モデル	条件	再現率	適合率	順序一致率
gpt-4.1-mini	Stage 1: アラート起点	4/14	4/14	0/2
gpt-4.1-mini	Stage 2 : 入力からアラート除外	0/14	0/14	0/2
gpt-4.1-mini	Stage 3 : データベースからアラート除外	0/14	0/14	0/2
gpt-5.4-mini	Stage 1: アラート起点	13/14	13/14	1/2
gpt-5.4-mini	Stage 2 : 入力からアラート除外	14/14	14/14	1/2
gpt-5.4-mini	Stage 3 : データベースからアラート除外	8/14	8/14	0/2

- 実験
 - ステージ1~3で27個の行動列で3回ずつ実験を回す
- 考察
 - 復元出来た行動列出来なかった行動列を分類し考察
 - モデルの性能によってどの程度行動復元が変化するかを考察